



**NANYANG
TECHNOLOGICAL
UNIVERSITY**
SINGAPORE

*Addressing Issues in Generative AI System
Design and Deployment*

Part 2-Chapter 2: Secure design principles for Generative AI application

Ong Chin Ann

Lecturer

College of Computing & Data Science
(chinann.ong@ntu.edu.sg)



COPYRIGHT STATEMENT

- All course materials, including but not limited to, lecture slides, handout and recordings, are for your own educational purposes only. **All the contents of the materials are protected by copyright, trademark or other forms of proprietary rights.**
- All rights, title and interest in the materials are owned by, licensed to or controlled by the University, unless otherwise expressly stated. **The materials shall not be uploaded, reproduced, distributed, republished or transmitted in any form or by any means, in whole or in part, without written approval from the University.**
- You are also not allowed to take any photograph, film, audio record or other means of capturing images or voice of any contents during lecture(s) and/or tutorial(s) and reproduce, distribute and/or transmit any form or by any means, in whole or in part, without the written permission from the University.
- Appropriate action(s) will be taken against you including but not limited to disciplinary proceeding and/or legal action if you are found to have committed any of the above or infringed the University's copyright.

Part 2-Topic 2: Secure design principles for Generative AI application

- What are the common practices for secure design?
- What are the available guideline/principles for secure design?

Generic Secure Design Principles

NCSC Guidelines for Secure AI System Development

- Raise staff awareness of threats and risks
- Model the threats to your system
- Design your system for security as well as functionality and performance
- Consider security benefits and trade-offs when selecting your AI model

Staff Awareness

- Most system owner / senior leaders understand threats to secure AI and the mitigation. But subordinate or other staff i.e. software engineer, analyst, data scientist etc, may not.
- End user (often internal staff) might be completely unaware of AI security threats.
- **Solution:** Staff training and upskilling, Staff orientation / mandatory "onboarding" processes.



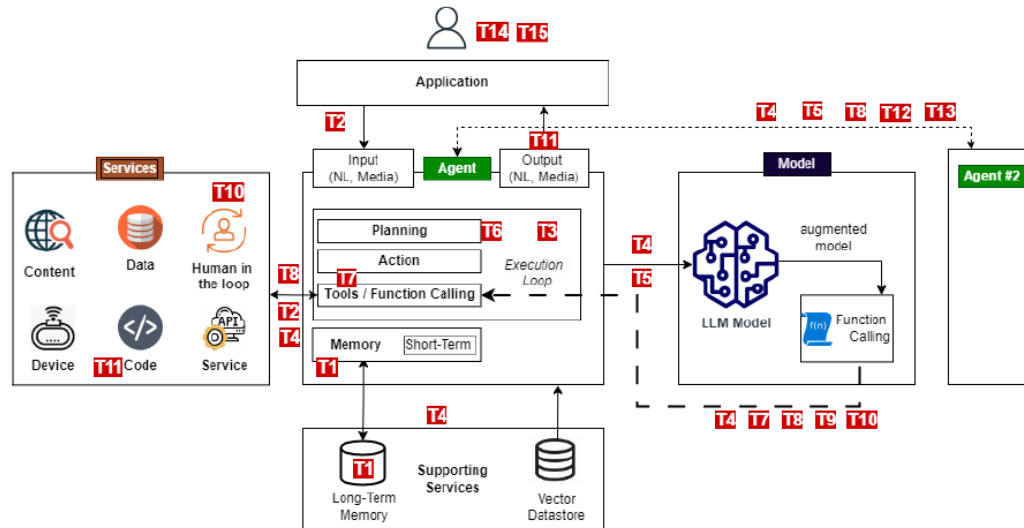
Threat Modelling

- Different types of data used in a system may influence its value as a target to an attacker.
- Some threat may grow as AI systems increasing in its value and user base.
- apply a holistic process to assess the threats to your system,
- understanding the potential impacts to the system, users, organisations, and wider society if an AI component is compromised or behaves unexpectedly.
- assessing the impact of AI-specific threats and documenting decision making.



Example of Agentic AI App Threat Modelling

Threat Model Summary:



Detailed Threat Model:

TID	Threat Name	Threat Description	Mitigations
T1	Memory Poisoning	Memory Poisoning involves exploiting an AI's memory systems, both short and long-term, to introduce malicious or false data and exploit the agent's context. This can lead to altered decision-making and unauthorized operations.	Implement memory content validation, session isolation, robust authentication mechanisms for memory access, anomaly detection systems, and regular memory sanitization routines. Require AI-generated memory snapshots for forensic analysis and rollback if anomalies are detected.
T2	Tool Misuse	Tool Misuse occurs when attackers manipulate AI agents to abuse their integrated tools through deceptive prompts or commands, operating within authorized permissions. This includes Agent Hijacking , where an AI agent ingests adversarial manipulated data and subsequently executes unintended actions, potentially triggering malicious tool interactions. For more information on Agent Hijacking see https://www.nist.gov/news .	Enforce strict tool access verification, monitor tool usage patterns, validate agent instructions, and set clear operational boundaries to detect and prevent misuse. Implement execution logs that track AI tool calls for anomaly detection and post-incident review.

Agentic AI - OWASP Lists Threats and Mitigations

Balancing between Security and Functionality

Supply Chain Security - *choosing whether to develop in house or use external components.*

- your choice to train a new model, use an existing model (with or without fine-tuning) or access a model via an external API is appropriate to your requirements.
- your choice to work with an external model provider includes a **due diligence evaluation** of that provider's own security posture.
- if using an external library, you complete a due diligence evaluation
 - to ensure the library has controls that prevent the system loading untrusted models without immediately exposing themselves to arbitrary code execution
- **implement scanning and isolation/sandboxing** when importing third-party models or serialised weights, which should be treated as untrusted third-party code and could enable remote code execution.

Balancing between Security and Functionality

- if using an external APIs, apply **appropriate controls** to data that can be sent to services outside of your organisation's control, such as requiring users to log in and confirm before sending potentially sensitive information.
- apply **appropriate checks and sanitisation** of data and inputs; this includes when incorporating user feedback or continuous learning data into your model, recognising that training data defines system behaviour



Photo by [Isaac Li Shung Tan](#) on [Unsplash](#)

Best Practices

- integrate AI software system development into **existing secure development and operations** best practices e.g. [DevSecOps](#)
- all elements of the AI system are written in **appropriate environments** using coding practices and languages that reduce or eliminate known classes of vulnerabilities where plausible.
- apply **appropriate restrictions / guardrail** if AI components need to trigger actions, for example amending files or directing output to external systems



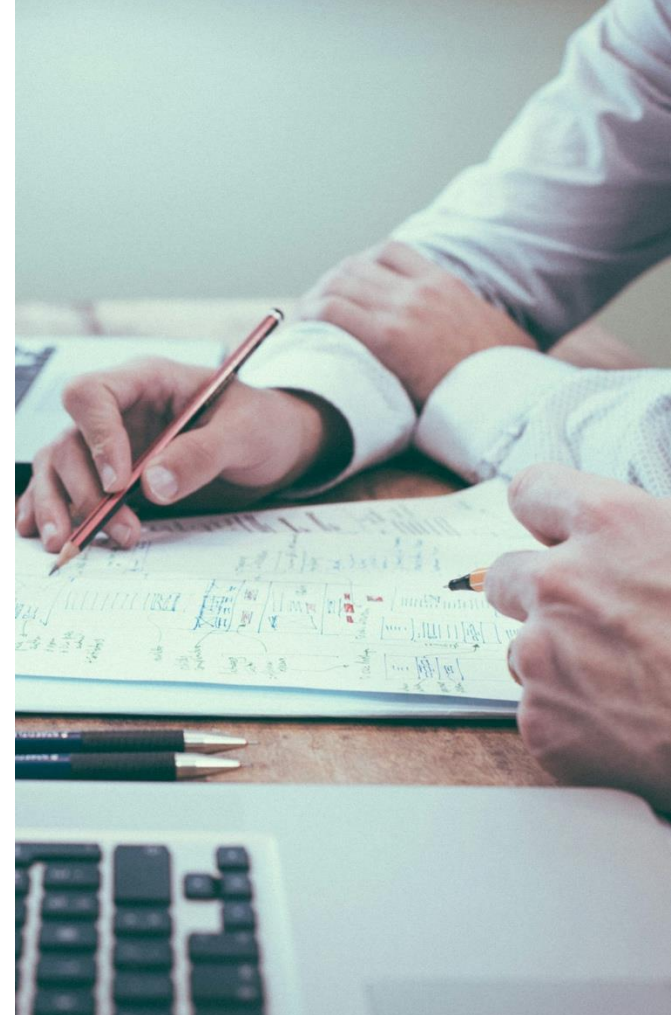
Other Issues and Considerations

decisions around user interaction are informed by AI-specific risks

- your system provides users with usable outputs **without revealing unnecessary levels of detail** to a potential attacker.
- if necessary, your system provides **effective guardrails around model outputs**
- if offering an API to external customers or collaborators, apply **appropriate controls that mitigate attacks** on the AI system via the API
- integrate the most secure settings into the system by default (**Secure by Default**)
- Apply [least privilege principles](#) to limit access to a system's functionality
- **explain riskier capabilities to users** and **require users to opt in** to use them.
- **communicate prohibited use cases**, and, where possible, **inform users of alternative** solutions.

Security Benefits and Trade-Offs

- Choice of AI model will involve balancing a range of requirements.
- This includes choice of model architecture, configuration, training data, training algorithm and hyperparameters.
- Your decisions are informed by your threat model, and are regularly reassessed as AI security research advances and understanding of the threat evolves.



Security Benefits and Trade-Offs

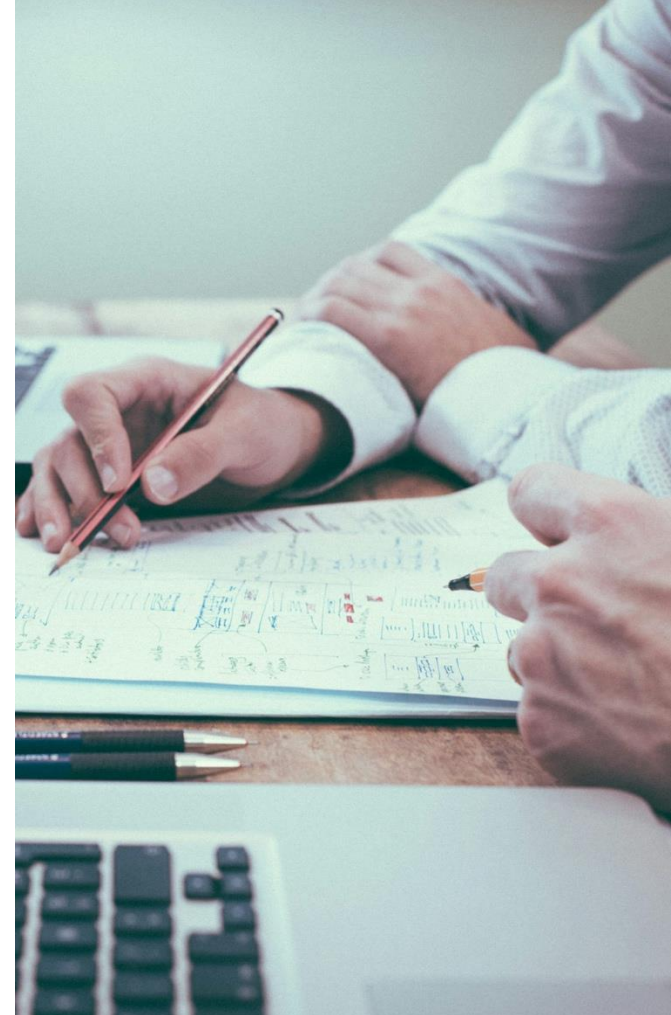
Consideration when choosing AI Model

- **complexity of the model** – i.e. the chosen architecture and number of parameters;
- your selection will affect how much training data it requires and how robust it is to changes in input data when in use
- the **appropriateness of the model** for your use case and/or feasibility of adapting it to your specific need (for example by fine-tuning)
- the ability to align, interpret and **explain your model's outputs** (for example for debugging, audit or regulatory compliance); there may be benefits to using simpler, more transparent models over large and complex ones which are more difficult to interpret
- **characteristics of training dataset(s)**, including size, integrity, quality, sensitivity, age, relevance and diversity

Security Benefits and Trade-Offs

Consideration when choosing AI Model

- the **value** of using model hardening (such as adversarial training), regularisation and/or privacy enhancing techniques
- the provenance and supply chains of components including the model or foundation model, training data and associated tools



Principles for the Security of Machine Learning/GenAI Projects

- These principles are aimed at anyone developing, deploying or operating a system with a machine learning (ML) / AI component.
- Help developers, engineers, decision makers and risk owners make informed decisions about the design, development, deployment and operation of their ML systems.
- However, they are not a comprehensive assurance framework to grade a system or workflow, and do not provide a checklist.
- These principles can be considered in addition to established cyber security, risk management, and incident response best practice.
- Best to follow the '**Secure by Design**' principles developed by the US Cybersecurity and Infrastructure Security Agency (CISA), the UK National Cyber Security Centre (NCSC)

Source: <https://www.ncsc.gov.uk/collection/machine-learning-principles>

Every technology provider must take ownership at the executive level to ensure their products are secure by design

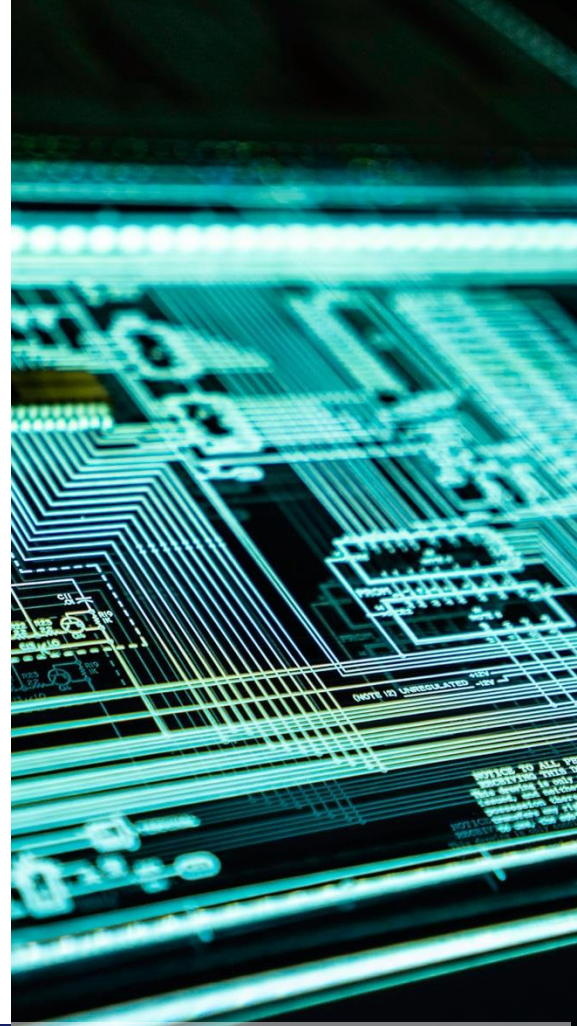
WHAT IS “SECURE BY DESIGN”?



Secure by Design

- “**Secure by design**” means that technology products are built in a way that reasonably protects against malicious cyber actors successfully gaining access to devices, data, and connected infrastructure.
- Software manufacturers should perform a risk assessment to identify and enumerate prevalent cyber threats to critical systems, and then include protections in product blueprints that account for the evolving cyber threat landscape

[Secure by Design | CISA](#)





PRINCIPLE 1

Take ownership of customer security outcomes

The burden of security should not fall solely on the customer. Software manufacturers have a responsibility to ensure that their products are designed and developed with security as a top priority.



PRINCIPLE 2

Embrace radical transparency and accountability

Software manufacturers should share information they learn from product deployments and vulnerabilities to help other manufacturers learn what to do and what not to do.



PRINCIPLE 3

Lead from the top

Executives should prioritize security as a critical element of product development across the organization.



Secure by Design Core Principles

Software manufacturers are encouraged to adopt a strategic focus that prioritizes software security.

Three core principles was defined to guide software manufacturers in building software security into their design processes prior to development, configuration, and shipment of their products.

[Secure by Design: What Does It Mean & How to Reasonably Implement It](#)



Secure by Design Core Principles

Each principles provides a brief explanations, reasoning, benefits, and example of practices:

- Security by Default Practices
- Secure Product Development Practices
- Pro Security Business Practices

Principle 1: Take Ownership of Customer Security Outcomes

- Manufacturers invest in product security efforts that include application hardening, application features, and application default settings.
- **Application hardening** - security must be “baked in,” and not “bolted on”.
 - Security measures i.e. input validation and sanitization, use memory safe programming language, uses hardware backed cryptographic key management etc...
- **Application features (capabilities)** – which help maintain and increase the security posture of customer.
 - Additional layers of securities i.e. MFA, RBAC, TLS etc...
- **Default settings** – secure setting set “out of the box”
 - Elimination of default password, disabled all security controls and only enable the essential features etc...
 - Notify administrator if some security feature has been toggle off by end user or other system users.
 - More discussion later on “Secure by Default” topic.

Take Ownership of Customer Security Outcomes

- Reduce hardening guide size along with software products
 - Some hardening guides are hard to find and are not well supported
 - Some are complex to implement, occasionally requiring software development or cybersecurity skill to get activated / enabled
- As a result, customers are taking on the responsibility to harden multiple instances of software or systems, often in resource constrained environments.
- Software manufacturers have a responsibility to ensure that their products are designed and developed with security as a top priority



Secure by Default Practices

Eliminate Default
Password

Conduct Field
Test

Reduce
Hardening Guide
Size

Discourage use of
unsafe legacy
features

Implement
attention
grabbing alert

Create secure
configuration
templates

Secure Product Development Practices

Document conformance
to Secure SDLC
Framework

Document conformance
to Cybersecurity
Performance Goals
(CPGs)

Vulnerability
Management

Responsibly use open
source software, library,
and frameworks

Provide secure defaults
for Developers

Foster Software
Developer Workforce
that Understands
Security

Securing Monitoring
(SIEM & SOAR)

Align with Zero Trust
Architecture
(Secure Deployment)

SIEM – Security Incident Event Management

SOAR – Security Orchestration, Automation, and Response

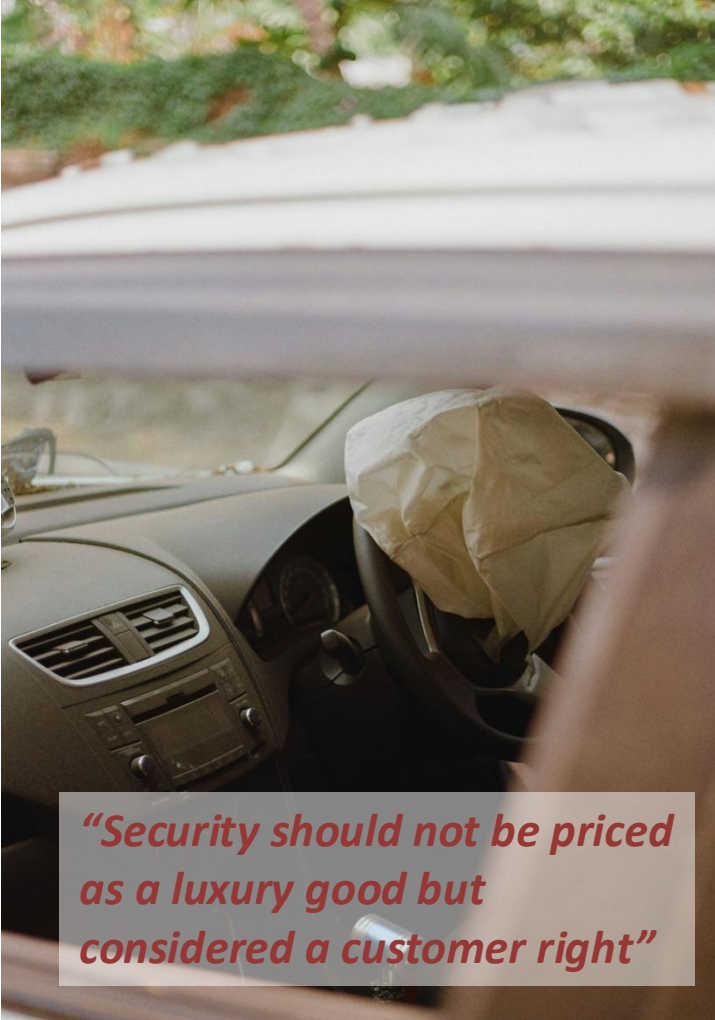
Pro Security Business Practices

Provide logging at
no additional
charges

Eliminate hidden
taxes

Embrace Open
Standard

Provide Upgrading
Tooling

A photograph showing the interior of a car from the driver's perspective. The dashboard, steering wheel, and a deployed airbag are visible. The airbag is a light-colored, crumpled fabric bag that has inflated from the center of the steering wheel. The background shows a blurred view of the road and greenery outside the car window.

***“Security should not be priced
as a luxury good but
considered a customer right”***



Principle 2: Embrace Radical Transparency and Accountability

- Software manufacturers should pride themselves in delivering safe and secure products
- Differentiating themselves from the rest of the manufacturer community based on their ability to do so.



Photo by [Hal Gatewood](#) on [Unsplash](#)

When practitioners discuss radical transparency, there is a tendency for the conversation to get bogged down in a concern that they are providing a “roadmap for attackers”

SO, WHY SHOULD ORGANIZATION EMBRACE TRANSPARENCY?

“ Radical transparency will help distribute that information and benefit the defenders more than our adversaries. ”

Transparency helps the industry establish conventions

Benefiting Organization

- helps those conventions change over time in response to customer needs
- forces decisions around security to be made early in the development process
- builds accountability into the product
- Provide customers information to help them make purchasing decisions not just on price and features, but on security as well
- public disclosure of the attack motivate the improvements the company made to prevent and detect future attacks

Peer and Industry

- helps manufacturers with fewer resources learn from those with more mature and capable resources.
- help peer organizations mature their SDLCs.
- The collective industry would benefit from more information sharing on topics such as strategies to measure the cost of security defects and to eliminate classes of vulnerability
- companies would benefit by lightening the load through collaboration and transparency

Secure by Default Practices

Publish aggregate
security-relevant
statistics and trends

Publish patching
statistics

Publish data on
unused privileges



Secure Product Development Practices

Establish internal security controls

Publish high-level threat models

Publish detailed secure SDLC self-attestations

Embrace vulnerability transparency

Publish Software Bills of Materials (SBOMs)

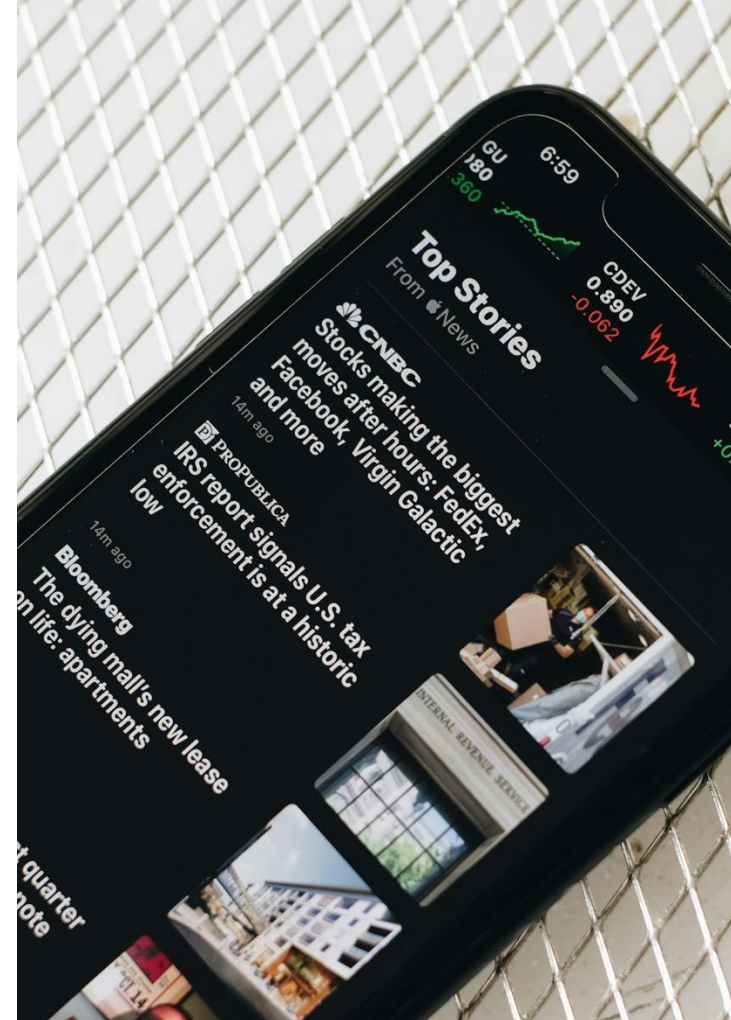
Pro Security Business Practices

Publicly name a secure by design senior executive sponsor

Publish a memory-safety roadmap

Publish a secure by design roadmap

Publish results



Principle 3: Lead from the Top



While technical subject matter expertise is critical to product security, it is not a matter that can be solely left to technical staff.

It is a business priority that must start at the top

Photo by [Campaign Creators](#) on [Unsplash](#)

Principle 3: Lead from the Top

- the incentives for customer safety begin well before the product design phase
- begin with business goals and implicit and explicit objectives and desired outcomes.
- Only when senior leaders make security a business priority, creating internal incentives and fostering an across-the-board culture to make security a design requirement, will they achieve the best results
- security is a sub-category of product quality



Photo by [Brett Jordan](#) on [Unsplash](#)

Demonstrating this Principle

Include details of a secure by design program in corporate financial reports.

Provide regular reports to your board of directors

Empower the secure by design executive

Create meaningful internal incentives

Create a secure by design council

Create and evolve customer councils

Secure by Design Tactics

- Use of secure by design tactics, including principles that reference SSDF practices
- Software manufacturers should develop a written roadmap to adopt more secure by design software development practices across their portfolio

NIST Special Publication 800-218

Secure Software Development Framework (SSDF) Version 1.1:

*Recommendations for Mitigating
the Risk of Software Vulnerabilities*

Murugiah Souppaya
Karen Scarfone
Donna Dodson

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-218>

NIST
National Institute of
Standards and Technology
U.S. Department of Commerce

Summary

- AI Security should be incorporated at the early stages of AI (Software) Development Life Cycle – Shift Left Concept in DevSecOps.
- The organization need to strive for the balance between security and features.
- The development team could start with Threat Modelling using SDLC artifacts.
- The development team should be mindful of security benefits and trade-offs when selecting/using AI model through the development life cycle.
- The development team should adopt “secure by default” approach when designing the system.
- The organization should embrace radical transparency and accountability
- Organization should also be aware of threats and risks for usage of GenAI powered systems.
- After all, the AI Security initiative must be led and start from the top and senior management

References

- NCSC Guidelines for Secure AI System Development
- Secure by Design:
<https://www.cisa.gov/securebydesign>

Guidelines for secure AI system development

